

LAPORAN PRAKTIKUM DEVSECOPS

FONDASI TEORETIS DAN KERANGKA KERJA



Disusun Oleh:

Muhamad Reza Muktasib

3126640060

D4 RPL IT B

BAB I PENDAHULUAN

1.1 Latar Belakang

Transformasi digital menuntut organisasi untuk mempercepat delivery perangkat lunak guna merespons kebutuhan pasar yang dinamis. Dalam konteks ini, DevSecOps hadir sebagai evolusi dari pendekatan DevOps yang mengintegrasikan aspek keamanan sejak tahap awal perancangan (*shift-left*) hingga operasional produksi (*shift-right*). DevSecOps bukan sekadar penambahan alat pemindai (*scanner*) pada pipeline CI/CD, melainkan sebuah sistem sosio-teknis yang melibatkan transformasi budaya, kolaborasi lintas fungsi, standarisasi proses, dan penyediaan bukti jaminan (*evidence*) yang dapat diaudit. Penetapan baseline laboratorium pada tahap awal ini menjadi fondasi penting untuk memastikan seluruh eksperimen dan kontrol keamanan berikutnya dapat direproduksi secara konsisten.

1.2 Tujuan

1. Menjelaskan DevSecOps sebagai sistem sosio-teknis, bukan sekadar penambahan alat pemindai ke pipeline.
2. Memetakan praktik DevSecOps ke kelompok praktik NIST SSDF, panduan OWASP, dan jaminan rantai pasok SLSA.
3. Membedakan konsep *shift-left*, *shift-right*, *security gate*, serta penyediaan bukti jaminan (*evidence*) yang dapat diaudit.
4. Menyusun baseline laboratorium dan kriteria keberhasilan eksperimen yang aman, legal, dan dapat direplikasi.

BAB II DASAR TEORI

2.1 Transformasi Digital dan DevOps

Transformasi digital merupakan perubahan mendasar dalam cara organisasi menciptakan nilai dengan memanfaatkan data, aplikasi, dan infrastruktur sebagai satu sistem yang terintegrasi. DevOps lahir untuk memperkecil jarak antara kebutuhan bisnis yang dinamis dan kemampuan operasional TI melalui kolaborasi erat antara tim pengembangan (*development*) dan operasi (*operations*). Prinsip utamanya melibatkan siklus belajar yang pendek, penggunaan data umpan balik yang andal, serta pengurangan ukuran *batch* perubahan untuk meningkatkan kecepatan dan stabilitas *delivery*.

2.2 Evolusi SDLC Menuju DevSecOps

Model pengembangan perangkat lunak telah berevolusi dari model *Waterfall* yang berurutan namun lambat dalam memberikan umpan balik, menuju model Agile yang iteratif. DevOps kemudian memperluas prinsip Agile ke seluruh aliran *delivery* dengan otomatisasi CI/CD. Akhirnya, DevSecOps muncul sebagai evolusi lebih lanjut yang mengintegrasikan kontrol keamanan ke dalam *lifecycle* yang sama. Praktik ini menerapkan prinsip *shift-left* (analisis keamanan sedini mungkin) dan *shift-right* (pemantauan serta deteksi ancaman saat *runtime* operasional) yang didukung oleh bukti jaminan (*evidence*) terverifikasi.

BAB III

PELAKSANAAN PRAKTIKUM

3.1 Persiapan Baseline Laboratorium

Praktikum ini bertujuan untuk menyiapkan struktur direktori kerja terpadu serta merekam versi seluruh komponen perangkat lunak yang digunakan guna memastikan seluruh eksperimen dapat direproduksi secara konsisten (*reproducible*).

Perintah yang dijalankan pada host Linux/VM:

```
# Membuat struktur direktori kerja DevSecOps
```

```
mkdir -p ~/devsecops-lab/{app,policy,reports,sbom,keys}
cd ~/devsecops-lab
```

```
# Pemeriksaan versi komponen dan runtime engine
```

```
docker version
docker compose version
git --version
openssl version
curl --version
```

```
# Pemeriksaan opsi keamanan kernel dan Docker daemon
```

```
docker info --format '{{json .SecurityOptions}}'
```

3.2 Dokumentasi Praktikum

1. Akses SSH ke lingkungan virtual machine / VPS

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\rezam> ssh ubuntu@43.173.2.7
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-181-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon Aug 31 06:48:14 PM CST 2026

System load:  0.09          Processes:      150
Usage of /:   79.9% of 39.26GB Users logged in:   0
Memory usage: 51%          IPv4 address for eth0: 10.11.0.5
Swap usage:   10%

*** System restart required ***
Last login: Sun Aug 30 06:35:42 2026 from 140.213.118.151
ubuntu@VM-0-5-ubuntu:~$
```

2. Pembuatan struktur direktori ~/devsecops-lab/{app,policy,reports,sbom,keys}

```
ubuntu@VM-0-5-ubuntu:~$ mkdir -p ~/devsecops-lab/{app,policy,reports,sbom,keys}
ubuntu@VM-0-5-ubuntu:~$ ls -la ~/devsecops-lab
total 28
drwxrwxr-x 7 ubuntu ubuntu 4096 Aug 31 18:50 .
drwxr-x-- 8 ubuntu ubuntu 4096 Aug 31 18:50 ..
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 app
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 keys
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 policy
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 reports
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 sbom
ubuntu@VM-0-5-ubuntu:~$
```

3. Berpindah ke direktori kerja utama ~/devsecops-lab

```
ubuntu@VM-0-5-ubuntu:~$ cd ~/devsecops-lab
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ ls
app  keys  policy  reports  sbom
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

4. Verifikasi instalasi dan versi docker version

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ docker version

Client:
 Version:           29.1.3
 API version:       1.52
 Go version:        go1.24.4
 Git commit:        29.1.3-0ubuntu3~22.04.2
 Built:             Wed Apr 29 22:18:59 2026
 OS/Arch:           linux/amd64
 Context:           default

Server:
 Engine:
  Version:          29.1.3
  API version:       1.52 (minimum version 1.44)
  Go version:        go1.24.4
  Git commit:        29.1.3-0ubuntu3~22.04.2
  Built:             Wed Apr 29 22:18:59 2026
  OS/Arch:           linux/amd64
  Experimental:      false
 containerd:
  Version:          2.2.1
  runc:
   Version:         1.3.4-0ubuntu1~22.04.1
  docker-init:
   Version:         0.19.0
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

5. Verifikasi versi docker compose version

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ docker compose version
Docker Compose version 2.40.3+ds1-0ubuntu1~22.04.1
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

6. Verifikasi versi Git dengan git --version

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ git --version
git version 2.34.1
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

7. Verifikasi versi OpenSSL dengan openssl version

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ openssl version
OpenSSL 3.0.2 15 Mar 2022 (Library: OpenSSL 3.0.2 15 Mar 2022)
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

8. Verifikasi versi cURL dengan curl --version

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ curl --version
curl 7.81.0 (x86_64-pc-linux-gnu) libcurl/7.81.0 OpenSSL/3.0.2
zlib/1.2.11 brotli/1.0.9 zstd/1.4.8 libidn2/2.3.2 libpsl/0.21.0
Release-Date: 2022-01-05
Protocols: dict file ftp ftps gopher http https imap ldap mqtt ...
Features: alt-svc AsynchDNS HSTS HTTP2 HTTPS-proxy IPv6 SSL TLS-SRP
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

9. Pemeriksaan fitur keamanan aktif host dengan docker info --format '{{json .SecurityOptions}}'

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ docker info --format '{{json .SecurityOptions}}'
[{"name=apparmor,profile=default","name=seccomp,profile=builtin",
 "name=cgroupns"}]
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

3.3 Verifikasi dan Skenario Pengujian

Berikut adalah matriks pengujian dan verifikasi kriteria keberhasilan praktikum Bab 1:

[✓] **Docker daemon dapat diakses oleh akun praktikum dan Docker Compose menggunakan plugin v2**

Evidence: Docker Client dan Docker Server Engine versi 29.1.3 serta Docker Compose plugin v2.40.3 dapat diakses langsung oleh user ubuntu tanpa kendala perizinan (*permission denied*).

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ docker version
Client:
Version:           29.1.3
API version:       1.52
Go version:        go1.24.4
Git commit:        29.1.3-0ubuntu3~22.04.2
Built:             Wed Apr 29 22:18:59 2026
OS/Arch:           linux/amd64
Context:           default

Server:
Engine:
Version:          29.1.3
API version:       1.52 (minimum version 1.44)
Go version:        go1.24.4
Git commit:        29.1.3-0ubuntu3~22.04.2
Built:             Wed Apr 29 22:18:59 2026
OS/Arch:           linux/amd64
Experimental:      false
containerd:
Version:           2.2.1
runc:
Version:           1.3.4-0ubuntu1~22.04.1
docker-init:
Version:           0.19.0
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

[✓] **Direktori reports, sbom, dan keys tidak dipublikasikan sebagai web root**

Evidence: Struktur direktori kerja laboratorium berada di direktori lokal ~/devsecops-lab/ yang terisolasi dan perizinan direktori sensitif keys/ dikonfigurasi ketat dengan chmod 700 (drwx-----).

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ ls -ld app keys policy reports sbom
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 app
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 keys
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 policy
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 reports
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 sbom
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ chmod 700 keys && ls -ld keys
drwx----- 2 ubuntu ubuntu 4096 Aug 31 18:50 keys
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

[✓] **SecurityOptions menampilkan mekanisme keamanan host Linux yang aktif**

Evidence: Perintah docker info --format '{{json .SecurityOptions}}' membuktikan profil isolasi keamanan aktif pada host, mencakup apparmor, seccomp (profile=builtin), dan cgroupns.

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ docker info --format '{{json .SecurityOptions}}'
["name=apparmor,profile=default","name=seccomp,profile=builtin",
 "name=cgroupns"]
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

[✓] **Penyusunan satu paragraf threat statement komprehensif**

Evidence: Terverifikasi pada Subbab 4.2 melalui tabel threat modeling dan penyusunan satu paragraf threat statement komprehensif untuk seluruh aset direktori laboratorium.

BAB IV HASIL DAN PEMBAHASAN

4.1 Analisis Hasil

Pencatatan versi perangkat lunak (Docker Engine 29.x, Docker Compose v2.x, Git, OpenSSL, dan cURL) menjadi bukti awal (*baseline evidence*) yang krusial. Hasil pemindaian kerentanan pada pipeline keamanan sangat bergantung pada versi engine, database CVE, dan parser yang aktif. Pemeriksaan SecurityOptions membuktikan bahwa mekanisme keamanan tingkat kernel Linux (seperti *apparmor*, *seccomp*, dan *cgroup*) telah aktif dan siap digunakan untuk membatasi hak akses serta mengisolasi container dari sistem host.

4.2 Analisis Ancaman (Threat Modeling)

Aset	Aktor Ancaman	Jalur Serangan	Dampak Bisnis
keys/ (Kunci Kriptografi & Signing)	Penyerang eksternal / akun lokal tak sah	Kebocoran <i>private key</i> akibat izin akses longgar atau terekspos ke <i>web root</i> / VCS	Kompromi tanda tangan digital (<i>supply chain attack</i>), pemalsuan identitas rilis, hilangnya integritas artefak
policy/ (Aturan Keamanan OPA/Rego)	Pengembang internal / penyerang dengan hak tulis lokal	Modifikasi atau <i>tampering</i> aturan <i>security gate</i> pada runner atau host	Pelolosan artefak rentan (<i>bypass security gate</i>) ke lingkungan produksi
reports/ & sbom/ (Laporan Audit & SBOM)	Penyerang eksternal (fase <i>reconnaissance</i>)	Akses tidak sah ke direktori laporan audit yang terpapar sebagai <i>web root</i> publik	Pengungkapan informasi (<i>information disclosure</i>) daftar kerentanan (CVE) untuk serangan terarah
app/ (Kode Sumber Aplikasi)	Penyerang / aktor internal	Penyusupan kode berbahaya (<i>backdoor</i>) atau penempatan <i>hardcoded secrets</i> pada direktori kerja	Kompromi keamanan aplikasi sejak tahap kompilasi dan build

Threat Statement:

Sebagai *baseline* laboratorium DevSecOps, aset kritis yang dikelola dalam struktur direktori `~/devsecops-lab/` mencakup kunci kriptografi (`keys/`), aturan kebijakan gerbang keamanan (`policy/`), inventaris komponen serta laporan audit kerentanan (`sbom/`, `reports/`), dan kode sumber aplikasi (`app/`). Aktor ancaman dapat memanfaatkan jalur serangan berupa kesalahan konfigurasi izin akses berkas (seperti *world-readable/writable permissions*) atau paparan direktori kerja sebagai *web root* publik. Dampak bisnis yang ditimbulkan meliputi kompromi rantai pasok perangkat lunak (*software supply chain attack*), kebocoran rahasia kriptografi, manipulasi kebijakan gerbang keamanan (*security gate bypass*), serta *reconnaissance* terarah terhadap daftar kerentanan sistem.

```
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ ls -ld app keys policy reports sbom
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 app
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 keys
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 policy
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 reports
drwxrwxr-x 2 ubuntu ubuntu 4096 Aug 31 18:50 sbom
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$ chmod 700 keys && ls -ld keys
drwx----- 2 ubuntu ubuntu 4096 Aug 31 18:50 keys
ubuntu@VM-0-5-ubuntu:~/devsecops-lab$
```

4.3 Analisis Konfigurasi Keamanan (Security Hardening)

Berdasarkan analisis ancaman terhadap struktur direktori kerja laboratorium, langkah-langkah penguatan keamanan (*security hardening*) diterapkan sebagai berikut:

1. **Penerapan Prinsip Least Privilege pada Izin Akses Direktori (POSIX Permissions):** Direktori sensitif seperti `keys/` dikonfigurasi dengan izin ketat `chmod 700 (drwx-----)` dan berkas kunci privat di dalamnya dengan `chmod 600 (-rw-----)`, sehingga hanya pemilik (*owner*) yang dapat membaca dan mengeksekusinya (sebagaimana diverifikasi pada Gambar 11).
2. **Pencegahan Eksposur Web Root:** Memastikan direktori `reports/`, `sbom/`, dan `keys/` tidak pernah dijadikan dokumen root pada web server publik (Nginx/Apache) ataupun dipublikasikan tanpa mekanisme otentikasi/enkripsi.
3. **Pemberlakuan .gitignore dan Secret Exclusion:** Mengonfigurasi berkas `.gitignore` pada direktori kerja utama untuk mencegah berkas kunci (`*.key`, `*.pem`, `keys/`) dan kredensial sensitif terunggah secara tidak sengaja ke repositori Git publik.
4. **Verifikasi Mekanisme Keamanan Host (SecurityOptions):** Memanfaatkan isolasi kernel tingkat host (*AppArmor*, *Seccomp*, dan *cgroup*) yang terdeteksi aktif pada Docker daemon untuk membatasi kapabilitas container runtime dan mencegah potensi *container breakout* ke filesystem host.

4.4 Analisis Masalah dan Solusi (Troubleshooting)

Dalam penyiapan baseline laboratorium, kendala operasional yang dapat terjadi meliputi:

1. **Izin Akses Daemon Docker Tanpa Sudo:** Jika user non-root tidak dapat menjalankan perintah Docker (error `permission denied`), solusinya adalah memasukkan user ke group docker (`sudo usermod -aG docker $USER`) dan memuat ulang group dengan `newgrp docker`.
2. **Kesesuaian Versi Komponen:** Perbedaan versi tool antara workstation lokal dan server build CI/CD dapat menyebabkan hasil pemindaian yang inkonsisten. Solusinya adalah mendokumentasikan baseline dan memanfaatkan containerized runners dengan image versi terkunci.

4.5 Evaluasi dan Latihan Mandiri

1. Mengapa DevSecOps tidak dapat direduksi menjadi penambahan scanner pada pipeline?

Menurut saya penambahan alat seperti *scanner* ke pipeline CI/CD hanya bentuk teknis dengan penambahan workflow dan proses, padahal tugas DevSecOps tidak hanya itu, mitigasi juga merupakan langkah awal dalam DevSecOps, mengidentifikasi *threat actor*. Terkadang penggunaan alat dapat membantu tetapi tidak bisa menemukan *edge case* dari sisi manusia itu sendiri, sehingga keamanan perlu dirancang dari awal dan menjadi tanggung jawab baik DevSecOps dan developer itu sendiri.

2. Evidence apa yang membedakan klaim kontrol dari kontrol yang benar-benar terverifikasi?

Hal yang terpenting dalam *evidence* terverifikasi adalah telemetri atau metadata. Bukti hasil yang terverifikasi dari seorang ahli mungkin seperti *pentester* atau QA dapat membuat itu menjadi berbeda karena bereputasi dan berbeda dengan klaim kontrol yang tidak terverifikasi terkhususnya yang hanya asumsi.

3. Bagaimana shared responsibility memengaruhi ownership risiko dan tindak lanjut temuan?

Shared responsibility dalam sebuah tim dibagi antara developer dan tim Ops, di mana developer memastikan tidak adanya kode yang dapat mengundang *threat* masuk, baik dalam penggunaan *3rd party library* dan lingkungan pengembangannya, sedangkan Ops berperan melindungi atau isolasi terhadap infra dan runtime dari aplikasi dengan memfasilitasi otomatisasi. Dengan pembagian ini, temuan kerentanan tidak lagi menjadi ajang saling lempar tanggung jawab, melainkan dikelola bersama sebagai prioritas *backlog* untuk segera ditindaklanjuti.

BAB V KESIMPULAN

DevSecOps adalah mekanisme pengelolaan risiko dan penyediaan bukti jaminan (*evidence*) yang terintegrasi pada seluruh siklus hidup *delivery* perangkat lunak. Keberhasilan implementasi DevSecOps ditentukan oleh keterpaduan antara budaya kolaborasi, proses tata kelola, dan otomatisasi kontrol keamanan. Penetapan baseline laboratorium pada Bab 1 ini memberikan landasan operasional yang solid dan dapat direplikasi untuk eksperimen keamanan, pemindaian kerentanan, serta pengerasan sistem pada bab-bab berikutnya.

BAB VI DAFTAR PUSTAKA

1. NIST SP 800-218 Secure Software Development Framework (SSDF) v1.1.
2. OWASP DevSecOps Guideline.
3. Supply-chain Levels for Software Artifacts (SLSA) v1.0.
4. DevOps Concept-Day1